

Threat Analysis Report

รายงานวิเคราะห์ช่องโหว่ Buffer
Overflow ใน GNU Inetutils telnetd
ซึ่งอาจนำไปสู่การรันโค้ดด้วยสิทธิ์ Root
CVE-2026-32746

25/03/2025

TLP:CLEAR





สารบัญ

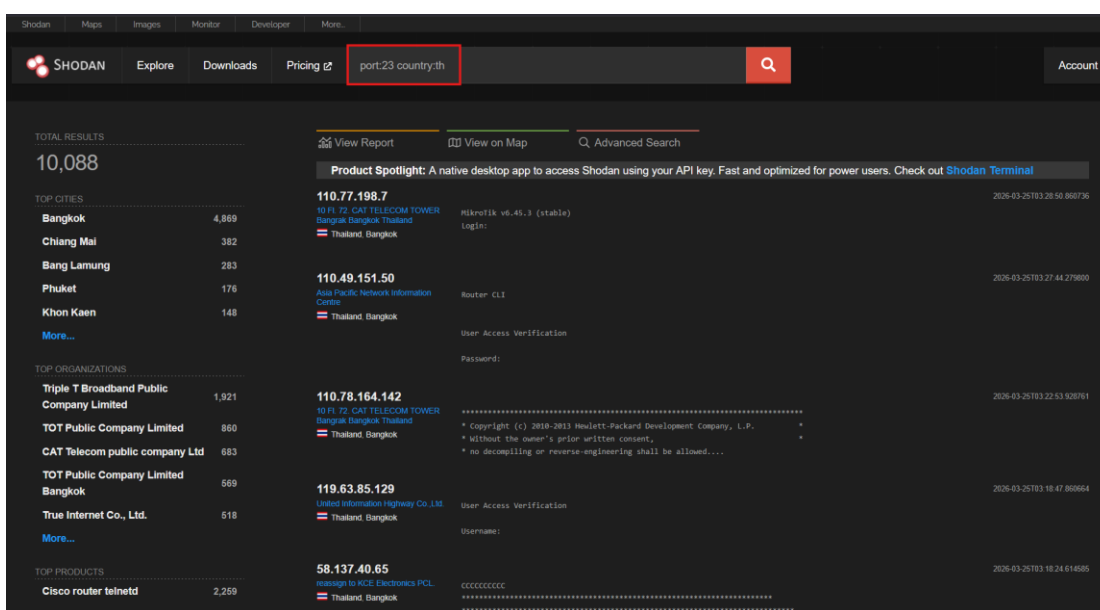
สารบัญ.....	2
บทสรุปสำหรับผู้บริหาร.....	3
การวิเคราะห์เชิงเทคนิค.....	4
Technique Tactics and Procedures (MITRE ATT&CK).....	7
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ.....	8
อ้างอิง (References).....	10



บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้เป็นการวิเคราะห์ช่องโหว่ใหม่ในประเภทของ Buffer Overflow ในรหัส CVE-2026-32746 โดยมีระดับความรุนแรง CVSS 9.8 ซึ่งถูกประกาศในวันที่ 19 มีนาคม 2569 ที่ผ่านมา ช่องโหว่ดังกล่าวเป็นช่องโหว่ที่ใช้ประโยชน์จาก LINEMODE SLC (Set Linemode Characters) negotiation handler ที่อยู่ใน GNU inetutils ของ telnet daemon ในเวอร์ชันที่ต่ำกว่า 2.8 ทั้งหมด ส่งผลอาจจะทำให้เปิดช่องทางให้ผู้ไม่หวังดีสามารถที่จะรันโค้ดได้โดยไม่ต้องผ่านการยืนยันตัวตนใด ๆ เพียงแค่ผ่านการเชื่อมต่อพอร์ต 23

ช่องโหว่นี้ส่งผลกระทบต่ออุปกรณ์ที่มีการใช้งาน GNU inetutils Telnetd และพอร์ต 23 บนระบบปฏิบัติการที่เป็น Linux, Unix-like หรืออุปกรณ์เครือข่าย/Embedded Systems ที่ใช้งานชุดเครื่องมือดังกล่าว ซึ่งในปัจจุบันนี้จากการตรวจสอบเบื้องต้นมีอุปกรณ์มากในประเทศไทยที่ยังเปิดใช้งานพอร์ต 23 อยู่ หากหน่วยงานหรืออุปกรณ์ของท่านไม่ได้มีความจำเป็นที่จะต้องใช้งานบริการ telnet และพอร์ต 23 ควรเร่งดำเนินการปิดการใช้งาน (Disable) พอร์ต 23 และพิจารณาเปลี่ยนไปใช้งานบริการ SSH ที่มีความปลอดภัยมากกว่าเพื่อลดความเสี่ยงในการโจมตีจากช่องโหว่นี้





การวิเคราะห์เชิงเทคนิค

สาเหตุ: ต้นเหตุของปัญหาเกิดจากข้อผิดพลาดแบบ Buffer Overflow ในฟังก์ชัน `add_slc()` ซึ่งใช้จัดการ SLC (Set Linemode Characters) โดยมีการเขียนข้อมูลในรูปแบบ SLC triplet (3 bytes ต่อ Triplet) ลงใน buffer `slcbuf` ที่มีขนาดจำกัด (108 bytes) แม้ว่าจะมีการตรวจสอบขนาดของ buffer แต่เงื่อนไขในการตรวจสอบขนาดผิดพลาด ทำให้สามารถเขียนข้อมูลเกินขอบเขตของ buffer ได้เมื่อมีการส่ง SLC entries จำนวนมาก ส่งผลให้เกิด memory corruption และอาจกระทบต่อข้อมูลหรือ pointer ที่อยู่ติดกันในหน่วยความจำ ซึ่งสามารถนำไปสู่การดำเนินการเพื่อควบคุมการทำงานของโปรแกรม หรือทำ arbitrary write และ Remote Code Execution ได้

เป้าหมาย: องค์กรหรือผลิตภัณฑ์ใด ๆ ที่ใช้งาน GNU Inetutils telnetd ร่วมกับการใช้งาน SLC ที่มีช่องโหว่ ได้แก่

1. อุปกรณ์ที่เป็นระบบปฏิบัติการ Linux ที่มี inetutils เช่น Debian, Ubuntu, RHEL, SUSE และมีการเปิดใช้งาน Telnetd (Telnet Daemon)
2. ระบบ Embedded และอุปกรณ์ IoT ที่เปิดใช้งาน TELNET interface สำหรับการจัดการหรือควบคุม
3. Operational Technology (OT) ที่ยังคงใช้งาน telnet สำหรับอุปกรณ์เก่า

ผลกระทบ: เนื่องจาก Telnetd มักทำงานในฐานะ root (ผ่าน inetd หรือ xinetd) แม้การโจมตีจะเป็นไปได้ยาก แต่ถ้าหากการโจมตีสำเร็จจะส่งผลให้สามารถควบคุมโฮสต์ได้ รวมถึง

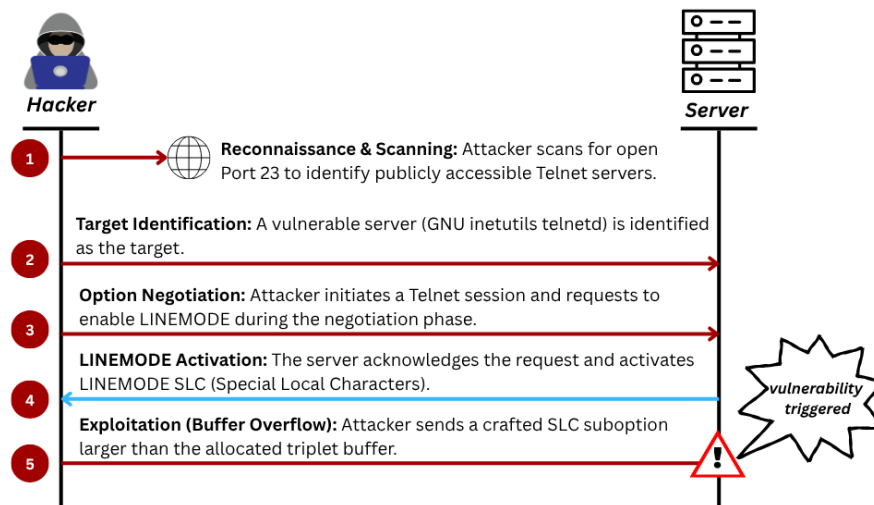
- การเรียกใช้โค้ดจากระยะไกลโดยพลการในฐานะ root (RCE)
- การติดตั้ง backdoor อย่างถาวร
- การขโมยข้อมูลสำคัญ
- การใช้โฮสต์เป็นจุดเริ่มต้นสำหรับการบุกรุกเครือข่ายเพิ่มเติม

การเชื่อมต่อเครือข่ายเพียงครั้งเดียวไปยังพอร์ต 23 ก็เพียงพอที่จะกระตุ้นช่องโหว่นี้ ไม่จำเป็นต้องใช้ข้อมูลในการยืนยันตัวตน ไม่ต้องการโต้ตอบกับผู้ใช้



ลำดับการโจมตี (Attack Flow)

1. **การค้นหาเป้าหมาย:** ผู้ไม่หวังดีจะทำการค้นหาเครื่องที่เปิด port 23 ออกสู่สาธารณะและมีการใช้งาน GNU inetutils telnetd
2. **เริ่มทำการเชื่อมต่อ:** ผู้ไม่หวังดีจะทำการเชื่อมต่อมายัง telnet ที่พอร์ต 23 เมื่อเครื่องเหยื่อยอมรับ Connection แล้วจะเข้าสู่ขั้นตอน Telnet Option negotiation Phase ตามปกติ โดยผู้ไม่หวังดีจะส่ง Parameter option เพื่อเปิดใช้งาน LINEMODE (IAC DO LINEMODE, IAC WILL LINEMODE, IAC SB LINEMODE DO SLC)
3. **โจมตีช่องโหว่:** ในระหว่างช่วงของการ Negotiation ผู้ไม่หวังดีสามารถที่จะส่ง LINEMODE SLC suboption ที่ถูกเตรียมขึ้นมาเป็นพิเศษ โดยจะมีขนาดเกินกว่า buffer ที่กำหนดไว้ (slcbuf ในฟังก์ชัน add_slc()) ซึ่งการตรวจสอบขนาดอาจจะความผิดพลาดจึงส่งผลให้สามารถที่จะส่งค่าเกินขนาดที่ควรจะเป็นและก่อให้เกิดการ Out of bounds write หรือ Buffer Overflow โดยเพย์โหลดจะส่งในรูปแบบ IAC SB LINEMODE SLC [crafted data] IAC SE
4. **การใช้ประโยชน์จากช่องโหว่และการรบกวนหน่วยความจำ:** เมื่อตัวแปรที่ถูกส่งเข้ามายัง Function มีขนาดใหญ่กว่าที่กำหนดและเกิดการเขียนข้อมูลเกินขอบเขต ส่งผลให้เกิดการรบกวนหรือเขียนทับตัวแปรข้างเคียงอย่างเช่น เขียนข้อมูลเกินขอบเขต, function pointers หรือ heap metadata จากผลกระทบดังกล่าวบนระบบที่ใช้งานกันปัจจุบันซึ่งเป็น 64 Bits นั้นการที่ผู้ไม่หวังดีจะ RCE บนเครื่องของเหยื่อนั้นเป็นไปได้ค่อนข้างยากจากข้อจำกัด NULL byte constraints, ASLR และอื่น ๆ หรือแม้แต่วระบบที่เป็นสถาปัตยกรรม x86 แบบ 32 Bits เองนั้นแม้ว่า Address space จะแคบกว่าและโครงสร้างระบบจะใกล้เคียงกันมากกว่าแต่ก็จะติดข้อจำกัดด้านขนาด Buffer ที่เล็ก พื้นที่วางเพย์โหลดจึงเล็กไปด้วย อีกทั้งข้อมูลที่ส่งเข้าไปจะถูกตรวจสอบและค่าบางค่าอาจจะไปตรงกับค่าของคำสั่งของ Protocol จึงอาจจะไม่ถูกนำไปเขียนใน Buffer
5. **ผลลัพธ์ที่เป็นไปได้:** แม้จะเป็นในทางทฤษฎี แต่ถ้าหากในอนาคตมีผู้ไม่หวังดีสามารถที่สร้างเพย์โหลดใหญ่พอและสามารถแก้ไข Pointer ได้จะทำให้ผู้ไม่หวังดีสามารถที่จะรันโค้ดบนเครื่องเหยื่อได้โดยไม่ได้รับอนุญาต



ภาพที่ 1 แผนภาพการโจมตี

การทดสอบช่องโหว่

การทดสอบการ trigger ช่องโหว่ของ telnetd นั้นทำบน Virtual Environment ที่มีเครื่องเป้าหมายเป็น Ubuntu-server x86 64 bits และมีการติดตั้ง telnet ในเวอร์ชัน 2.5 และเครื่องที่ใช้ในการกระตุ้นเป็น Kali Linux โดยใช้งานสคริปต์การทดสอบจาก watchTower Labs จากภาพจะพบว่าสามารถที่จะ Trigger ช่องโหว่ได้สำเร็จใน telnet เวอร์ชัน 2.5 แต่อย่างที่กล่าวไปข้างต้นว่าการที่จะยกระดับการโจมตีจากการอาศัยช่องโหว่ Buffer Overflow ไปสู่การ RCE หรือเข้าควบคุมเครื่องของเหยื่อนั้นแทบจะเป็นไปไม่ได้แค่ในทางทฤษฎี

[illegible]

[ภาพที่ 2 ภาพการทดลอง PoC การส่ง SLC suboption ที่ถูกสร้างขึ้นพิเศษ]

Technique Tactics and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Reconnaissance	T1595.002	Active Scanning: Vulnerability Scanning
Initial Access	T1190	Exploit Public-Facing Application
Execution	T1203	Exploitation for Client Execution
Privilege Escalation	T1068	Exploitation for Privilege Escalation
Defense Evasion	T1548	Abuse Elevation Control Mechanism



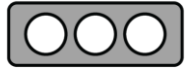
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- เฝ้าระวังในระดับเครือข่าย: ใช้งานอุปกรณ์ที่สามารถตรวจจับการเชื่อมต่อในระดับเครือข่ายได้ เช่น Firewall เพื่อเฝ้าระวังการเชื่อมต่อใหม่ที่มายังพอร์ต 23
- การตรวจจับการบุกรุก (Intrusion Detection): ควรมีการติดตั้งใช้งาน Network IDS Signature เพื่อเฝ้าระวังและแจ้งเตือน (Alert) ในกรณีที่พบชุดคำสั่ง LINEMODE SLC suboptions (IAC SB LINEMODE 0x03) ของโปรโตคอล Telnet ที่มีการส่ง Payload ขนาดใหญ่ผิดปกติ (เช่น มีขนาดข้อมูลในส่วน Suboption data มากกว่า 90 bytes) เพื่อตรวจจับความพยายามในการใช้ประโยชน์จากช่องโหว่

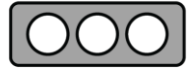
การป้องกัน (Prevention)

- ปิดใช้งานบริการ Telnet: ในกรณีที่ไม่ได้มีความจำเป็นต้องใช้งานบริการนี้ให้ดำเนินการ Disable service Telnet
- ปิดการใช้งานพอร์ต 23: หากมีความจำเป็นต้องใช้งาน ให้จำกัดการเข้าถึงและใช้งานสำหรับ IP ที่ได้รับอนุญาตหรือเป็น IP ภายในเท่านั้น
- อัปเดตเวอร์ชัน: ให้ดำเนินการอัปเดตเวอร์ชันที่สูงกว่าเวอร์ชันที่ได้รับผลกระทบ (≤ 2.7) ทันทีเมื่อมีการเผยแพร่เวอร์ชันที่ได้รับการแก้ไข แม้ในขณะนี้จะยังไม่มีการปล่อยแพตช์แก้ไข ช่องโหว่นี้ออกมาอย่างเป็นทางการ (30 มีนาคม 2569)



การรับมือ (Response)

- ในกรณีที่มีผู้ไม่หวังดีสามารถที่จะสร้างเพย์โหลดที่มีความสามารถมากพอที่จะเข้าควบคุมระบบได้ให้ดำเนินการดังนี้
 - แยกอุปกรณ์ที่ติดเชื้อ: หากตรวจพบการบุกรุก ให้รีบตัดการเชื่อมต่อเครื่องที่มีการบุกรุกนั้นออกจากเครือข่ายเพื่อป้องกันการแพร่กระจายพร้อมทั้งปิดการใช้งานพอร์ต 23 และทำการตรวจสอบเครื่องอื่น ๆ บนเครือข่ายว่ามีเครื่องอื่น ๆ อีกหรือไม่ที่ใช้งาน telnet
 - เก็บหลักฐานทางดิจิทัล: รักษาสภาพของเครื่องที่ติดเชื้อไว้เพื่อการวิเคราะห์หาสาเหตุและสืบสวน (Digital Forensics)
 - กำจัดไฟล์อันตรายและกู้คืนระบบ: ดำเนินการลบไฟล์และกิจกรรมที่ผู้ไม่หวังดีดำเนินการไว้และกู้คืนระบบจาก Backup ที่ปลอดภัยหลังจากได้รับการยืนยันว่าได้ทำการอัปเดตความปลอดภัยและแก้ไขช่องโหว่ต่าง ๆ เรียบร้อยแล้ว
 - รายงานเหตุการณ์: แจ้งเหตุการณ์ไปยังหน่วยงานที่เกี่ยวข้องภายในองค์กรและหน่วยงานด้านความมั่นคงปลอดภัยไซเบอร์



อ้างอิง (References)

1. National Vulnerability Database
<https://nvd.nist.gov/vuln/detail/CVE-2026-32746>
2. Dream's website "Vulnerability advisory: Pre-Auth Remote Code Execution via Buffer Overflow in telnetd LINEMODE SLC Handler"
<https://dreamgroup.com/vulnerability-advisory-pre-auth-remote-code-execution-via-buffer-overflow-in-telnetd-linemode-slc-handler/>
3. watchTower Labs's vulnerability research "A 32-Year-Old Bug Walks Into A Telnet Server (GNU inetutils Telnetd CVE-2026-32746 Pre-Auth RCE)"
<https://labs.watchtower.com/a-32-year-old-bug-walks-into-a-telnet-server-gnu-inetutils-telnetd-cve-2026-32746/>



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://dg.th/nsexlfob51>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th